

Entregable 1

Análisis y planificación del Pentest

Caso Aurora Market

Realizado por	Deyra Salazar
Fecha	septiembre 2026

¿Por qué se realiza este pentest? (objetivo del pentest)

Aurora Market es una tienda en línea, lo que significa que maneja de forma constante datos personales de sus clientes (nombres, direcciones, historial de compras) y, en algún punto del flujo de compra, información relacionada a pagos. A eso se suma que ya existe un antecedente concreto: un usuario reportó que pudo ver información que no le pertenecía. Ese aviso es justamente la señal de que puede existir una falla real en cómo la aplicación controla el acceso a los datos, y es la razón principal por la que se plantea esta evaluación.

El objetivo de esta actividad es elaborar el enfoque de trabajo antes de ejecutar herramientas. El valor de aporte para Aurora Market está en que les permite corregir estas fallas antes de que un atacante real las aproveche, en lugar de enterarse del problema por una denuncia pública, una filtración de datos o una demanda de un cliente afectado.

Alcance

Sí se evaluará

- Aplicación web
- Formas de registro, log in, log out, cambio de contraseña y recuperación de cuentas
- Cómo se gestionan las sesiones entre usuarios y los controles de autorización
- El alcance de los usuarios dentro de la aplicación: productos, carrito, consulta de información personal, pagos, etc.
- Cuentas administrativas
- Endpoints y APIs que usa la aplicación

No se evaluará

- Redes sociales de la empresa
- Correo electrónico empresarial y de empleados
- Dispositivos como laptops o celulares de los empleados
- Cuentas o sistemas de proveedores
- Phishing o ingeniería social
- Ataques de DDoS
- Dominios, equipos o sistemas que no estén autorizados de forma explícita

Autorización y condiciones

Permisos requeridos

- Autorización formal y por escrito de Aurora Market para realizar el pentest
- Identificación exacta de las URLs, dominios y sistemas autorizados por el cliente

- Definición de las técnicas de prueba permitidas y prohibidas
- Cuentas y credenciales de prueba para los distintos perfiles de usuario
- Autorización para realizar pruebas de explotación controlada
- Lista de contactos de emergencia de Aurora Market

Condiciones acordadas

- Las pruebas se realizarán en horarios no productivos o de baja criticidad para la plataforma
- No se ejecutarán acciones que interrumpan el servicio
- No se modificará ni se eliminará información de clientes
- No se accederá a información que no sea necesaria para demostrar la vulnerabilidad
- Si se detecta un riesgo crítico o una afectación al servicio, se detiene la prueba de inmediato y se notifica a los contactos de emergencia
- Toda la evidencia se almacenará y manejará de forma segura y confidencial

Horarios propuestos para el pentest

Aurora Market es un comercio electrónico, así que su tráfico más alto normalmente ocurre en las tardes y noches entre semana, y sobre todo los fines de semana, que es cuando más compras se realizan. Por eso, propongo realizar las pruebas entre semana (de lunes a jueves), en franjas de madrugada, aproximadamente entre la 1:00 a.m. y las 5:00 a.m., que es cuando la cantidad de usuarios reales conectados es mínima.

Se descartan los fines de semana porque es cuando más se vende, y se descartan también fechas cercanas a campañas o promociones (por ejemplo, Black Friday o Cyber Days), ya que en esos periodos cualquier lentitud o comportamiento inesperado de la aplicación tendría un impacto mucho mayor en el negocio.

Además, durante toda la ventana de pruebas debe haber un contacto técnico de Aurora Market disponible (aunque sea de forma remota), para poder avisar de inmediato si se detecta algo anómalo y detener la prueba si hiciera falta, tal como se definió en las condiciones acordadas.

Tipo de Pentest — Gray Box

Justificación

Se eligió Gray Box porque se está recibiendo cierta información previa de parte de Aurora Market, pero no todo el detalle interno de la aplicación. Concretamente, se sabe que:

- Existe una aplicación web
- Existen formas de autenticación
- Hay distintos tipos de usuario
- Existe una base de datos
- Se conoce el antecedente reportado por un usuario

Pero no se conoce la arquitectura interna, las tecnologías exactas que usan, cómo está protegida la aplicación, el código fuente ni las configuraciones internas del servidor. Ese nivel de conocimiento parcial es justamente lo que caracteriza a un pentest Gray Box: se prueba desde la perspectiva de un usuario que ya tiene algo de acceso o información (como podría ser un cliente registrado, o incluso un empleado con acceso limitado), pero sin la visibilidad total que tendría alguien del equipo de desarrollo.

Planificación

Objetivos

- Identificar vulnerabilidades y determinar su impacto real sobre Aurora Market

- Verificar los controles de autenticación y autorización de la aplicación

Alcance

Aplicación web de Aurora Market y los componentes que estén expresamente autorizados por el cliente.

Permisos y condiciones

Autorización escrita, pruebas controladas, horarios fuera de producción o fuera de los horarios críticos definidos, y prohibición total de afectar la información o la disponibilidad del servicio.

Metodología: PTES (Penetration Testing Execution Standard)

Se usará PTES porque ordena el trabajo en fases claras, desde la planificación hasta el informe final, lo cual encaja bien con este caso: primero se define el alcance y las reglas del juego, luego se recopila información sobre la aplicación, después se identifican y analizan las vulnerabilidades, se valida su explotación de forma controlada, se evalúa el impacto real para el negocio y finalmente se documentan los riesgos junto con las recomendaciones de corrección.

Recopilación de información previa

Antes de tocar la aplicación, es necesario reunir toda la información que se pueda sobre Aurora Market usando tanto fuentes internas (las que el propio cliente entrega) como fuentes abiertas (OSINT), sin salirse del alcance autorizado.

Por el lado de fuentes internas, se le pedirá a Aurora Market: las URLs y dominios exactos autorizados, la lista de funcionalidades principales de la aplicación, los tipos de usuario que existen, cuentas de prueba para cada perfil, los contactos técnicos, los horarios permitidos y las restricciones específicas de la prueba. Esta información se recopila directamente en reuniones previas con el cliente y quedando todo por escrito.

Por el lado de OSINT (fuentes abiertas), se puede complementar esa información pública que ya existe sobre Aurora Market sin necesidad de interactuar directamente con sus sistemas. Por ejemplo:

- Consultas de WHOIS, para conocer datos del registro del dominio (quién lo administra, fechas de registro, servidores DNS asociados)
- Revisión de certificados SSL/TLS en portales como crt.sh, que puede revelar subdominios que no se conocían
- Búsquedas avanzadas en Google (Google dorking) para encontrar archivos, paneles o información expuesta por error
- Herramientas como Wappalyzer o BuiltWith, para identificar qué tecnologías usa el sitio (framework, CMS, servidor web, librerías), lo cual ayuda a anticipar qué tipo de vulnerabilidades son más probables

Toda esta recopilación se hace de forma pasiva primero (sin generar tráfico hacia los sistemas de Aurora Market) y solo después se pasa a la recopilación activa, que ya implica interactuar directamente con la aplicación autorizada.

Dentro de las herramientas activas está OWASP ZAP, que se usará principalmente como proxy para interceptar y analizar el tráfico que se genera entre el navegador y la aplicación, y también para hacer un "spidering" o rastreo automático del sitio, que permite mapear todas las páginas, formularios y endpoints con los que cuenta la aplicación. También se usará Nmap, cuyo propósito acá es identificar qué puertos están abiertos y qué servicios corren detrás de ellos en el dominio o IP autorizados; esto sirve para saber, por ejemplo, si además del puerto web (80/443) hay otros servicios expuestos que no deberían estar accesibles desde afuera, como una base de datos o un panel de administración corriendo en un puerto poco común.

Recursos necesarios

- Equipo de pentesting
- Navegador web

- Proxy de análisis como Burp Suite u OWASP ZAP
- Nmap, para el escaneo de puertos y servicios
- Cuentas de prueba para los distintos perfiles
- Herramientas de reconocimiento y análisis web (Wappalyzer, whois, crt.sh)
- Sistema seguro para almacenar la evidencia recolectada

Programación

Las pruebas se realizarán en las fechas y horarios autorizados descritos anteriormente (madrugadas entre semana), organizando el trabajo en ventanas separadas para reconocimiento, análisis, validación de vulnerabilidades y elaboración del informe final, de manera que cada fase tenga tiempo suficiente y no se mezclen actividades que puedan generar ruido o confusión en los resultados.

Fases del Pentest

Reconocimiento

En esta fase se busca entender bien la superficie de ataque de la aplicación antes de empezar a buscar fallas puntuales. Concretamente, se recopilaría información sobre las tecnologías que usa Aurora Market, sus funcionalidades, endpoints, parámetros, mecanismos de autenticación y los tipos de usuario disponibles.

Para lograr esto, el trabajo se dividiría en dos partes. Primero, un reconocimiento pasivo, apoyado en lo que ya se recopiló como OSINT (tecnologías detectadas con Wappalyzer, subdominios encontrados en crt.sh, datos del dominio en WHOIS), para tener una idea general de con qué se está trabajando sin tocar aún los sistemas de la aplicación. Segundo, un reconocimiento activo dentro del alcance autorizado, navegando la aplicación como lo haría un usuario normal y registrando el flujo completo:

Registro → Login → Perfil → Productos → Carrito → Compra → Pedidos → Panel administrativo.

Dentro del reconocimiento activo también tendría sentido hacer un escaneo de puertos con Nmap sobre el dominio o IP autorizados, ya que esto permite confirmar qué servicios están realmente expuestos hacia afuera. Por ejemplo, si al escanear apareciera abierto un puerto de base de datos (como el 3306 de MySQL) o un panel de administración corriendo en un puerto distinto al 80/443, eso ya sería en sí mismo un hallazgo importante, porque ese tipo de servicios normalmente no deberían ser accesibles desde internet. También se usaría el spider de OWASP ZAP en paralelo, para mapear automáticamente todas las páginas y endpoints de la aplicación, y así no depender solo de la navegación manual.

El objetivo final de esta fase es tener un mapa completo de la aplicación (endpoints, formularios, roles de usuario, tecnologías) antes de pasar a buscar vulnerabilidades específicas.

Análisis de vulnerabilidades

Con el mapa de la aplicación ya construido, en esta fase se revisarían específicamente los siguientes puntos: autenticación, gestión de sesiones, autorización, control de acceso, validación de entradas, exposición de información y configuración de seguridad.

La herramienta principal para esta fase sería OWASP ZAP, usando su función de escaneo activo, que prueba automáticamente la aplicación contra vulnerabilidades comunes como inyección SQL, XSS, cabeceras de seguridad mal configuradas o cookies de sesión sin las protecciones adecuadas. El propósito de usar ZAP acá es tener una primera capa de detección rápida y amplia sobre toda la superficie mapeada en la fase anterior.

Sin embargo, dado que el antecedente reportado por Aurora Market tiene que ver específicamente con que un usuario pudo ver datos de otro, el análisis no se puede quedar solo en lo automático. Ahí es donde entraría Burp Suite (o el mismo ZAP en modo manual), para interceptar y modificar peticiones a mano, y así revisar puntualmente los controles de autorización: por ejemplo, tomar una petición donde se consulta un pedido y

cambiar el identificador por el de otro usuario, para ver si la aplicación valida correctamente que ese pedido le pertenece a quien lo está pidiendo. Este tipo de prueba manual es clave porque los escáneres automáticos casi nunca detectan bien las fallas de control de acceso (como IDOR), ya que requieren entender la lógica del negocio y no solo el formato de la petición.

En resumen, el propósito de esta fase es pasar de "aquí hay una aplicación con tal flujo" a "estas son las fallas concretas que existen y en qué parte de la aplicación están", combinando el escaneo automatizado con revisión manual dirigida al problema que ya se sabe que existe.

Explotación

En esta fase se validaría de manera controlada cada vulnerabilidad identificada, para comprobar si realmente puede ser aprovechada y qué tan grave sería. Siguiendo el ejemplo del control de acceso: se usarían dos cuentas de prueba autorizadas, donde el Usuario A solicita su propio pedido, se modifica el identificador de ese pedido, y se intenta consultar el pedido del Usuario B. Si la aplicación entrega esa información sin validar que le pertenece al Usuario A, ahí quedaría demostrada la falla de autorización.

Es importante remarcar que en esta actividad no se está ejecutando la explotación, solo se está explicando cómo se abordaría: la idea es limitarse a demostrar que la vulnerabilidad existe, evitando en todo momento acceder o modificar datos reales que no sean estrictamente necesarios para la prueba.

Post-explotación

Acá se buscaría entender hasta dónde podría llegar un atacante si efectivamente lograra explotar una de las vulnerabilidades encontradas, sin llegar a causar daño real a la plataforma. Se evaluaría si la falla permitiría, por ejemplo, acceder a otros datos, aumentar privilegios dentro de la aplicación, llegar a funciones administrativas, comprometer otras cuentas o exponer información sensible de más clientes.

Siguiendo el ejemplo anterior: acceso no autorizado a pedidos → exposición de nombres y direcciones → posible afectación a múltiples clientes, no solo a uno. Pero en ningún momento se realizarían acciones destructivas ni se descargarían grandes cantidades de registros; basta con demostrar el riesgo, no con explotarlo al máximo.

Informe

Finalmente, se documentarían todas las vulnerabilidades encontradas, con su evidencia correspondiente, el nivel de riesgo, el impacto que representa para Aurora Market y las recomendaciones para corregirlas. Por cada hallazgo se seguiría esta estructura: Vulnerabilidad → Evidencia → Activo afectado → Impacto → Probabilidad → Severidad → Recomendación, de forma que Aurora Market pueda entender rápidamente qué tan urgente es cada corrección y por dónde empezar.

Investigación sobre la metodología

Se eligió PTES (Penetration Testing Execution Standard) porque ofrece una estructura clara y ordenada para llevar a cabo la prueba de principio a fin, desde la planificación hasta el informe final. Para este caso resulta especialmente útil porque permite, antes de tocar nada, definir el alcance y las reglas de compromiso con Aurora Market; luego recopilar información sobre la aplicación (tanto interna como OSINT); después identificar y analizar las vulnerabilidades presentes; validar su explotación de forma controlada; evaluar el impacto real que tendrían para el negocio; y, finalmente, documentar los riesgos junto con recomendaciones concretas de seguridad. Esa secuencia ordenada es justamente lo que evita que una prueba de este tipo termine siendo improvisada o que se salte pasos importantes como la autorización o el reporte final.